

(1) Introduction

This report shows the comprehensive analysis of the infected Cobalt Strike attack based on the pcap file (traffic logs). The goal is to identify the infected system and how it is being attacked.

Section (2) talks about what tools used and how to perform the intrusion analysis.

Section (3) describe the results and evidence.

Section (4) summarize the whole analysis.

Section (5) shows the reference materials.

(2) Methodology

To reconstruct the sequence of events, I need to know the what, who, when, what, how.

The pcap file contains all the transaction logs. The Wireshark software is capable of finding every detail information about every packets in the infected system by “Follow TCP stream”, or by filtering in the display searching field, or by finding the statistics data.

Before diving into the details, “Zui” software is used to get a general idea of what is happening (it summarize the activities) and how it is happening. To trace how the system got infected, I filtered the alert events. (As shown in Fig1, searching : `event_type=="alert" | fuse | sort ts`). And then I export to an excel file—ZUI-ALERT.csv and placed in the folder “ZUI-ALERT” in github. (“ET” in the alert messages means emerging threats)



Fig1

As such, in order to view detail information (e.g. MAC address, hostname, domain), click the "Wireshark" button in Zui, and then switch between Zui and Wireshark.

Then, to indicate the infection, I use “VirusTotal” website to check whether IP or URL is malicious. (As Fig 2 below)

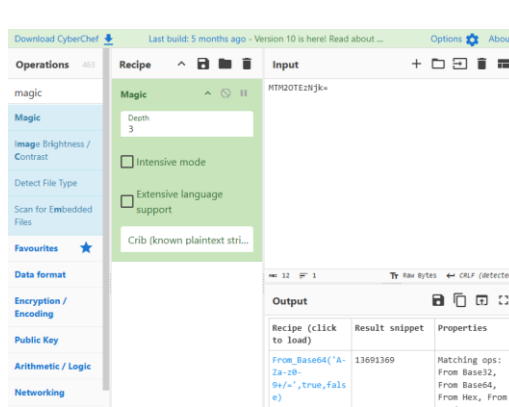


Fig3

Other tools like CyberChef is used to check the information hidden in the “garbled text”. (As Fig3 above)

Windows Terminal is used to check the name of the file located in the compressed file (As Fig 4 below).

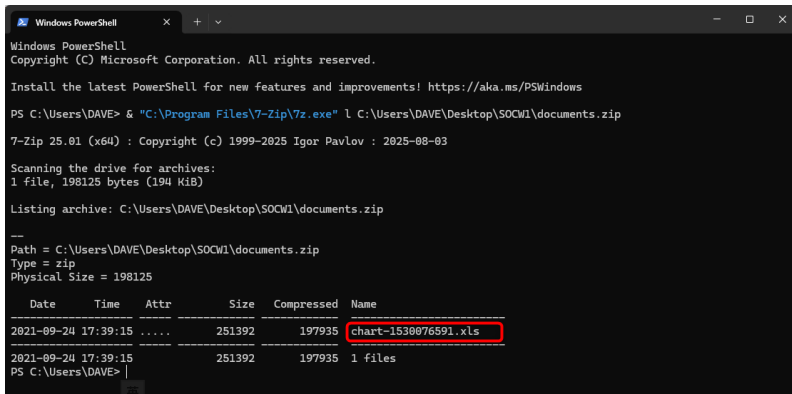


Fig 4

(3) Results

General Understanding:

From the question set, it is known that this is a “Cobalt Strike Attack”. Normally, the victim will send packets to the hacker server to show that “I am alive”. By investigating the ZUI-ALERT.csv (as state in Section 2), this “Cobalt Strike Attack” is broadly divided into four stages.

Phrase 1: Initial Infection (16:44-16:53)

The alert “ET MALWARE SQUIRRELWAFFLE Loader Activity (POST)” (Fig 5) means that the victims (10.9.23.102) is sending the packets to the hacker server (281.91.128.6). According to the alert, 281.91.128.6 is loading server. It will keep on loading malware or virus to the 10.9.23.102.

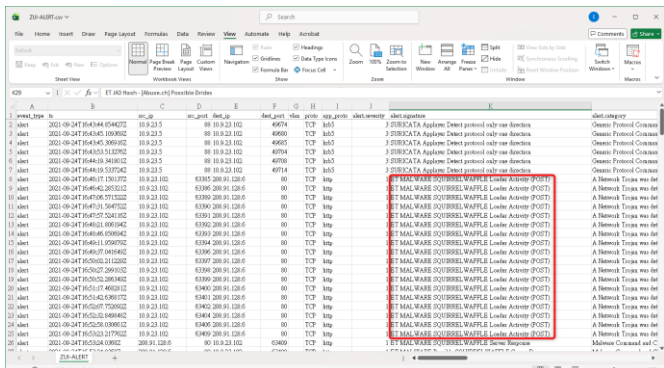
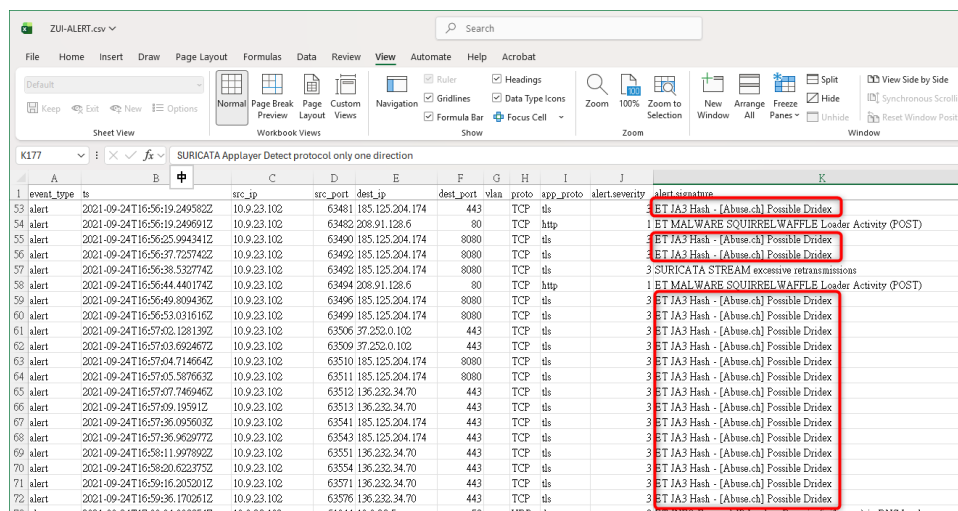


Fig 5

Phrase 2: Second-stage infection (16:53 – 17:00)

The alert shows:” ET JA3 Hash - [Abuse.ch] Possible Dridex”. That is, the victim is infected by Dridex. Dridex is Botnet. Dridex is loaded by SQUIRRELWAFFLE.

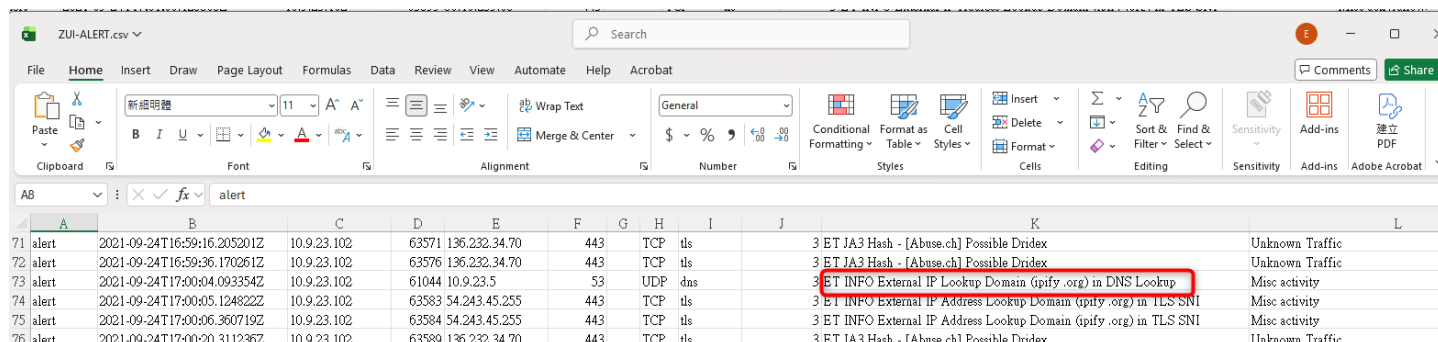


event_type	ts	src_ip	src_port	dest_ip	dest_port	vlan	proto	app_proto	alert.severity	alert.signature
53	2021-09-24T16:56:19.249582Z	10.9.23.102	63481	185.125.204.174	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
54	2021-09-24T16:56:19.249691Z	10.9.23.102	63482	208.91.128.6	80	TCP	http		1	ET MALWARE SQUIRRELWAFFLE Loader Activity (POST)
55	2021-09-24T16:56:25.994341Z	10.9.23.102	63490	185.125.204.174	8080	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
56	2021-09-24T16:56:37.725742Z	10.9.23.102	63492	185.125.204.174	8080	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
57	2021-09-24T16:56:38.532774Z	10.9.23.102	63494	185.125.204.174	8080	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
58	2021-09-24T16:56:44.440174Z	10.9.23.102	63494	208.91.128.6	80	TCP	http		1	ET MALWARE SQUIRRELWAFFLE Loader Activity (POST)
59	2021-09-24T16:56:49.809436Z	10.9.23.102	63496	185.125.204.174	8080	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
60	2021-09-24T16:56:53.031616Z	10.9.23.102	63499	185.125.204.174	8080	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
61	2021-09-24T16:57:02.128139Z	10.9.23.102	63506	37.252.0.102	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
62	2021-09-24T16:57:03.692467Z	10.9.23.102	63509	37.252.0.102	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
63	2021-09-24T16:57:04.714664Z	10.9.23.102	63510	185.125.204.174	8080	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
64	2021-09-24T16:57:05.387663Z	10.9.23.102	63511	185.125.204.174	8080	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
65	2021-09-24T16:57:07.746946Z	10.9.23.102	63512	136.232.34.70	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
66	2021-09-24T16:57:09.195912Z	10.9.23.102	63513	136.232.34.70	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
67	2021-09-24T16:57:36.095603Z	10.9.23.102	63541	185.125.204.174	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
68	2021-09-24T16:57:36.963977Z	10.9.23.102	63543	185.125.204.174	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
69	2021-09-24T16:58:11.997892Z	10.9.23.102	63551	136.232.34.70	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
70	2021-09-24T16:58:20.622373Z	10.9.23.102	63554	136.232.34.70	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
71	2021-09-24T16:59:16.205201Z	10.9.23.102	63571	136.232.34.70	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex
72	2021-09-24T16:59:36.170261Z	10.9.23.102	63576	136.232.34.70	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex

Fig 6

Phrase 3: Reconnaissance (17:00 -17:02)

The alert shows:” ET INFO External IP Lookup Domain (ipify .org) ”. The victim is asking ipify.org : what is the external IP of me. The malware needed this information to confirm the victim status and then report to C2 server later.

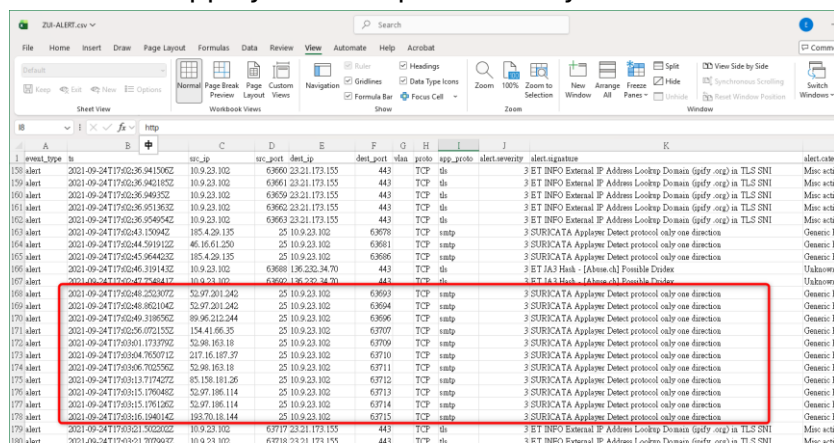


event_type	ts	src_ip	src_port	dest_ip	dest_port	vlan	proto	app_proto	alert.severity	alert.signature	dest.category
71	2021-09-24T16:59:16.205201Z	10.9.23.102	63571	136.232.34.70	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex	Unknown Traffic
72	2021-09-24T16:59:36.170261Z	10.9.23.102	63576	136.232.34.70	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex	Unknown Traffic
73	2021-09-24T17:00:04.093354Z	10.9.23.102	61044	10.9.23.5	53	UDP	dns		3	ET INFO External IP Lookup Domain (ipify .org) in DNS Lookup	Misc activity
74	2021-09-24T17:00:05.124822Z	10.9.23.102	63583	54.243.45.255	443	TCP	tls		3	ET INFO External IP Address Lookup Domain (ipify .org) in TLS SNI	Misc activity
75	2021-09-24T17:00:06.360719Z	10.9.23.102	63584	54.243.45.255	443	TCP	tls		3	ET INFO External IP Address Lookup Domain (ipify .org) in TLS SNI	Misc activity
76	2021-09-24T17:00:20.311236Z	10.9.23.102	63589	136.232.34.70	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex	Unknown Traffic

Fig 7

Phrase 4: Diffusion (17:02 onwards)

The victim becomes zombie and send the spam email (SMTP protocol) through port 25. (Fig7). The alert is “SURICATA Applayer Detect protocol only one direction”



event_type	ts	src_ip	src_port	dest_ip	dest_port	vlan	proto	app_proto	alert.severity	alert.signature	dest.category
159	2021-09-24T17:02:36.941506Z	10.9.23.102	63660	23.21.173.155	443	TCP	tls		3	ET INFO External IP Address Lookup Domain (ipify .org) in TLS SNI	Misc activity
160	2021-09-24T17:02:36.942183Z	10.9.23.102	63661	23.21.173.155	443	TCP	tls		3	ET INFO External IP Address Lookup Domain (ipify .org) in TLS SNI	Misc activity
161	2021-09-24T17:02:36.951863Z	10.9.23.102	63662	23.21.173.155	443	TCP	tls		3	ET INFO External IP Address Lookup Domain (ipify .org) in TLS SNI	Misc activity
162	2021-09-24T17:02:36.954954Z	10.9.23.102	63663	23.21.173.155	443	TCP	tls		3	ET INFO External IP Address Lookup Domain (ipify .org) in TLS SNI	Misc activity
163	2021-09-24T17:02:43.150942Z	185.426.135	25	10.9.23.102	63678	TCP	smtp		3	SURICATA Applayer Detect protocol only one direction	Generic P
164	2021-09-24T17:02:43.591912Z	46.16.61.250	25	10.9.23.102	63681	TCP	smtp		3	SURICATA Applayer Detect protocol only one direction	Generic P
165	2021-09-24T17:02:45.644625Z	185.426.135	25	10.9.23.102	63686	TCP	smtp		3	SURICATA Applayer Detect protocol only one direction	Generic P
166	2021-09-24T17:02:46.319143Z	10.9.23.102	63688	136.232.34.70	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex	Unknown Traffic
167	2021-09-24T17:02:46.754847Z	10.9.23.102	63692	136.232.34.70	443	TCP	tls		3	ET JA3 Hash - [Abuse.ch] Possible Dridex	Unknown Traffic
168	2021-09-24T17:02:46.255807Z	52.97.201.242	25	10.9.23.102	63693	TCP	smtp		3	SURICATA Applayer Detect protocol only one direction	Generic P
169	2021-09-24T17:02:46.862104Z	52.97.201.242	25	10.9.23.102	63694	TCP	smtp		3	SURICATA Applayer Detect protocol only one direction	Generic P
170	2021-09-24T17:02:49.319656Z	89.95.212.244	25	10.9.23.102	63696	TCP	smtp		3	SURICATA Applayer Detect protocol only one direction	Generic P
171	2021-09-24T17:02:56.072155Z	154.41.66.35	25	10.9.23.102	63707	TCP	smtp		3	SURICATA Applayer Detect protocol only one direction	Generic P
172	2021-09-24T17:03:01.173179Z	52.98.163.18	25	10.9.23.102	63709	TCP	smtp		3	SURICATA Applayer Detect protocol only one direction	Generic P
173	2021-09-24T17:03:04.765071Z	217.16.167.57	25	10.9.23.102	63710	TCP	smtp		3	SURICATA Applayer Detect protocol only one direction	Generic P
174	2021-09-24T17:03:06.702556Z	52.98.163.18	25	10.9.23.102	63711	TCP	smtp		3	SURICATA Applayer Detect protocol only one direction	Generic P
175	2021-09-24T17:03:13.717427Z	85.158.181.26	25	10.9.23.102	63712	TCP	smtp		3	SURICATA Applayer Detect protocol only one direction	Generic P
176	2021-09-24T17:03:15.170482Z	52.97.186.114	25	10.9.23.102	63713	TCP	smtp		3	SURICATA Applayer Detect protocol only one direction	Generic P
177	2021-09-24T17:03:15.176126Z	52.97.186.114	25	10.9.23.102	63714	TCP	smtp		3	SURICATA Applayer Detect protocol only one direction	Generic P
178	2021-09-24T17:03:16.104042Z	183.70.181.44	25	10.9.23.102	63715	TCP	smtp		3	SURICATA Applayer Detect protocol only one direction	Generic P
179	2021-09-24T17:03:21.502205Z	10.9.23.102	63717	23.21.173.155	443	TCP	tls		3	ET INFO External IP Address Lookup Domain (ipify .org) in TLS SNI	Misc activity
180	2021-09-24T17:03:31.979902Z	10.9.23.102	63718	23.21.173.155	443	TCP	tls		3	ET INFO External IP Address Lookup Domain (ipify .org) in TLS SNI	Misc activity

Fig 8

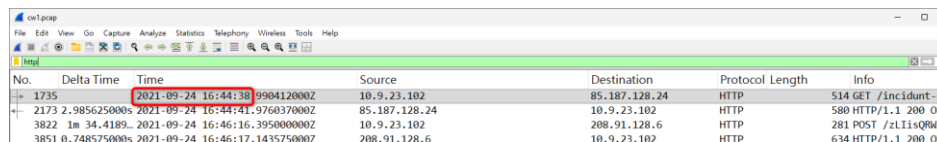
The roles of this Cobalt Strike attack infer with evidence as follow (will further explain):

C2 Server : 185.125.204.174 (Cobalt strike C2), 185.106.96.158(Cobalt strike C2), 281.91.128.6 (loader C2)
Victim : 10.9.23.102
Spy : 185.125.204.174, 136.232.34.70 (JA3 is the sign)
Qbot : 85.187.128.24 (IP in Q3)
Zombie : 10.9.23.102 (send spam emails to other IP)
Staging Server : 208.91.128.6

With above general understanding, let's further investigate in details with reference to the question set provided in advance.

Phrase 1 in the question set (Q1 - 8, Q13 -16.):

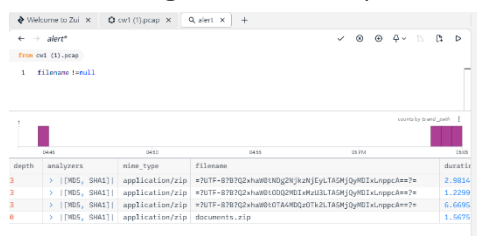
The initial malicious HTTP connection occur at 2021-09-24 16:44:38 (searching “http” in Wireshark as Fig SO_CW1_Q1 below). More precisely, it is the first handshake (SYN) of the TCP three way handshake.



No.	Delta Time	Time	Source	Destination	Protocol	Length	Info
1735		2021-09-24 16:44:38	9904120002	10.9.23.102	85.187.128.24	HTTP	514 GET /incident-cc
2173	2.985625000s	2021-09-24 16:44:41.976037000Z	85.187.128.24	10.9.23.102	HTTP	580 HTTP/1.1 200 OK	
3822	1m 34.4189...	2021-09-24 16:46:16.395000000Z	10.9.23.102	208.91.128.6	HTTP	281 POST /zLl1sQm4ZJ	
3851	0.748575000s	2021-09-24 16:46:17.143575000Z	208.91.128.6	10.9.23.102	HTTP	634 HTTP/1.1 200 OK	

Fig SO_CW1_Q1

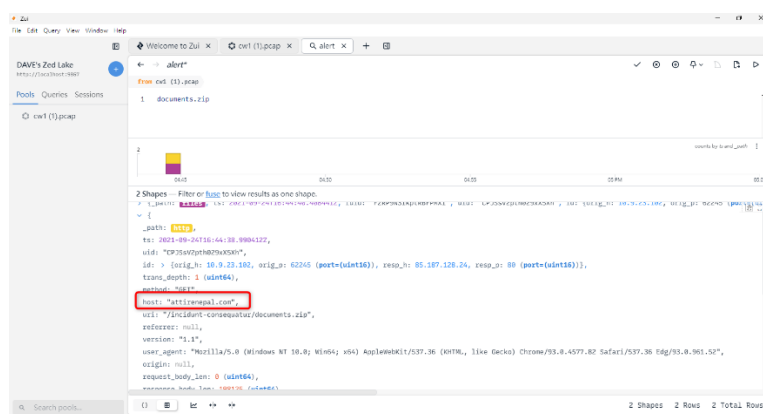
The name of the compressed file that the victim downloaded is “documents.zip” (by searching in Zui as shown in Fig SO_CW1_Q2)



depth	analyzers	mime_type	filename	duration
3	> [[TMS, SHA1]]	application/zip	#7uTF=8787Q2huah0tK0g2kxHjEyl1A3Hj0yM0Lxunpgdew7e	2.9814
3	> [[TMS, SHA1]]	application/zip	#7uTF=8787Q2huah0tK0g2kxHjEyl1A3Hj0yM0Lxunpgdew7e	1.2299
3	> [[TMS, SHA1]]	application/zip	#7uTF=8787Q2huah0tK0g2kxHjEyl1A3Hj0yM0Lxunpgdew7e	6.6596
6	> [[TMS, SHA1]]	application/zip	documents.zip	1.5676

Fig SO_CW1_Q2

The domain hosted the malicious compressed file is found by searching in Zui (Fig SO_CW1_Q3).



depth	analyzers	mime_type	filename	duration
2	> [[TMS, SHA1]]	application/zip	#7uTF=8787Q2huah0tK0g2kxHjEyl1A3Hj0yM0Lxunpgdew7e	2.9814
2	> [[TMS, SHA1]]	application/zip	#7uTF=8787Q2huah0tK0g2kxHjEyl1A3Hj0yM0Lxunpgdew7e	1.2299
2	> [[TMS, SHA1]]	application/zip	#7uTF=8787Q2huah0tK0g2kxHjEyl1A3Hj0yM0Lxunpgdew7e	6.6596
6	> [[TMS, SHA1]]	application/zip	documents.zip	1.5676

Fig SO_CW1_Q3

To avoid being infected, I just check the name inside the compressed file in terminal (Fig SO_CW1_Q4)

```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\DAVE> & "C:\Program Files\7-Zip\7z.exe" l C:\Users\DAVE\Desktop\SOCM1\documents.zip

7-Zip 25.01 (x64) : Copyright (c) 1999-2025 Igor Pavlov : 2025-08-03

Scanning the drive for archives:
1 file, 198125 bytes (194 KiB)

Listing archive: C:\Users\DAVE\Desktop\SOCM1\documents.zip

---
Path = C:\Users\DAVE\Desktop\SOCM1\documents.zip
Type = zip
Physical Size = 198125

  Date       Time       Attr      Size  Compressed  Name
  ----
2021-09-24 17:39:15 ..... 251392    197935  chart-1538076591.xls
2021-09-24 17:39:15 ..... 251392    197935  1 files
PS C:\Users\DAVE>
```

Fig SO_CW1_Q4

Use Zui to find out the traffic of the zip file (Fig SO_CW1_5A). Then, follow TCP stream in Wireshark to see the Server Header (Fig SO_CW1_5B)

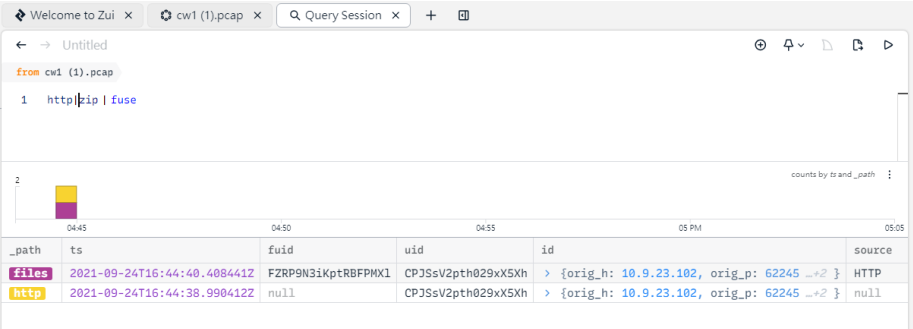


Fig SO_CW1_Q5A



Fig SO_CW1_Q5B

The version of the webserver of the malicious IP is found by follow TCP stream in Wireshark (Fig SO_CW1_Q6)

Fig SO_CW1_Q6

The three additional domains involved in downloading malicious files is between 16:45:11 to 16:45:30 (Fig SO_CW1_Q7)

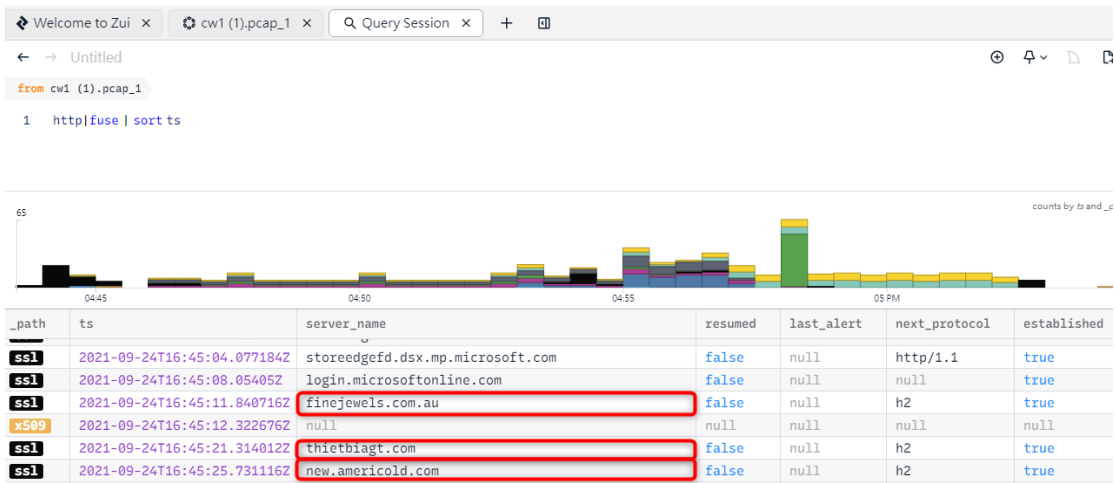


Fig SO_CW1_Q7

The CA issued SSL certificate is shown in Fig SO_CW1_Q8.



Fig SO_CW1_Q8

The post infection traffic was directed to the domain maldivehost.net (Fig SO_CW1_Q13A and 13B). That is 208.91.128.6. and load C2 server. It generate the virus to other infected IP or zombie.

event_type	ts	src_ip	dest_ip	src_port	dest_port	proto	app_proto	alert_severity	alert_signature	alert_category
alert	2021-09-24T16:43:44.854427Z	10.9.23.5	88 10.9.23.102	49674	TCP	krb5		3	SURICATA Applayer Detect protocol only one direction	Generic Protocol C
alert	2021-09-24T16:43:45.109369Z	10.9.23.5	88 10.9.23.102	49680	TCP	krb5		3	SURICATA Applayer Detect protocol only one direction	Generic Protocol C
alert	2021-09-24T16:43:45.306916Z	10.9.23.5	88 10.9.23.102	49685	TCP	krb5		3	SURICATA Applayer Detect protocol only one direction	Generic Protocol C
alert	2021-09-24T16:43:53.513276Z	10.9.23.5	88 10.9.23.102	49704	TCP	krb5		3	SURICATA Applayer Detect protocol only one direction	Generic Protocol C
alert	2021-09-24T16:44:19.341801Z	10.9.23.5	88 10.9.23.102	49708	TCP	krb5		3	SURICATA Applayer Detect protocol only one direction	Generic Protocol C
alert	2021-09-24T16:44:17.150137Z	10.9.23.102	63385 208.91.128.6	80	TCP	http		1	ET MALWARE SQUIRRELWAFFLE Loader Activity (POST)	A Network Trojan
alert	2021-09-24T16:46:42.285321Z	10.9.23.102	63386 208.91.128.6	80	TCP	http		1	ET MALWARE SQUIRRELWAFFLE Loader Activity (POST)	A Network Trojan
alert	2021-09-24T16:47:06.571522Z	10.9.23.102	63389 208.91.128.6	80	TCP	http		1	ET MALWARE SQUIRRELWAFFLE Loader Activity (POST)	A Network Trojan

Fig SO_CW1_Q13A

Protocol	Length	Info
DNS	91	Standard query response 0xf236 A maldivehost.net A 208.91.128.6
DNS	91	Standard query response 0x9cfc A maldivehost.net A 208.91.128.6

Fig SO_CW1_Q13B

For questions 14 to 16 is about the information about this load C2 server(208.91.128.6) or the packet information that sent to this IP. (Fig SO_CW1_Q14, Fig SO_CW1_Q15, Fig SO_CW1_Q16)

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

tcp.stream eq 104

No. Delta Time Time Source Destination Protocol Length Info

3807 2021-09-24 16:46:16.141471000Z 10.9.23.102 208.91.128.6 TCP 66 63385 →

3820 0.252048000s 2021-09-24 16:46:16.393519000Z 208.91.128.6 10.9.23.102 TCP 58 http(80)

3821 0.000483000s 2021-09-24 16:46:16.394002000Z 10.9.23.102 208.91.128.6 TCP 54 63385 →

3822 0.00098000s 2021-09-24 16:46:16.395000000Z 10.9.23.102 208.91.128.6 HTTP 281 POST /zLiisQRWZi9C

3823 0.000181000s 2021-09-24 16:46:16.395181000Z 10.9.23.102 208.91.128.6 TCP 54 63385 →

3824 0.000681000s 2021-09-24 16:46:16.395862000Z 10.9.23.102 208.91.128.6 P 54 http(80)

3825 0.000181000s 2021-09-24 16:46:16.396043000Z 10.9.23.102 208.91.128.6 P 54 http(80)

3851 0.748281000s 2021-09-24 16:46:17.144324000Z 10.9.23.102 208.91.128.6 TP 634 HTTP/1.1

3852 0.006281000s 2021-09-24 16:46:17.150605000Z 10.9.23.102 208.91.128.6 P 54 http(80)

3853 0.000181000s 2021-09-24 16:46:17.150786000Z 10.9.23.102 208.91.128.6 P 54 63385 →

Wireshark · Follow TCP Stream (tcp.stream eq 104) · cw1.pcap

POST /zLiisQRWZi9CQs=aDixzHTgtfjMcGypGenp1duF5eiW9f3k= HTTP/1.1
Host: maldivehost.net
Content-Length: 112

Dw8YBxsEgmYFAAEJfR4NQK9mLTyQzDK5KyQmOyRGQlxEB04Lzk/EyYrMi1hOT8vIyM7IhcNPzsOKjguFgkLSIIjCxFRgwFagIIDQUGBoFD0FJ

HTTP/1.1 200 OK
Date: Fri, 24 Sep 2021 16:46:15 GMT
Server: Apache/2.4.49 (cPanel) OpenSSL/1.1.1l mod_bwlimited/1.4

Fig SO_CW1_Q14

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

tcp.stream eq 104

No. Delta Time Time Source Destination Protocol Length Info

3807

2021-09-24 16:46:16.141471000Z

10.9.23.102

208.91.128.6

TCP

66

63385 → http(80) [S

3820

0.252048000s

2021-09-24 16:46:16.393519000Z

208.91.128.6

10.9.23.102

TCP

58

http(80) → 63385 [S

3821

0.000483000s

2021-09-24 16:46:16.394002000Z

10.9.23.102

208.91.128.6

TCP

54

63385 → http(80) [A

3822

0.000980000s

2021-09-24 16:46:16.395000000Z

10.9.23.102

208.91.128.6

HTTP

281

POST /zLiisQRWZi9C

3823

0.000181000s

2021-09-24 16:46:16.395181000Z

10.9.23.102

208.91.128.6

TCP

54

63385 → http(80) [F

Fig SO_CW1_Q15

Wireshark · Follow TCP Stream (tcp.stream eq 104) · cw1.pcap

POST /zLiisQRWZi9CsaDixzHTgtfjMcGypGenp1dwF5ewV9f3k= HTTP/1.1
Host: maldivehost.net
Content-Length: 112

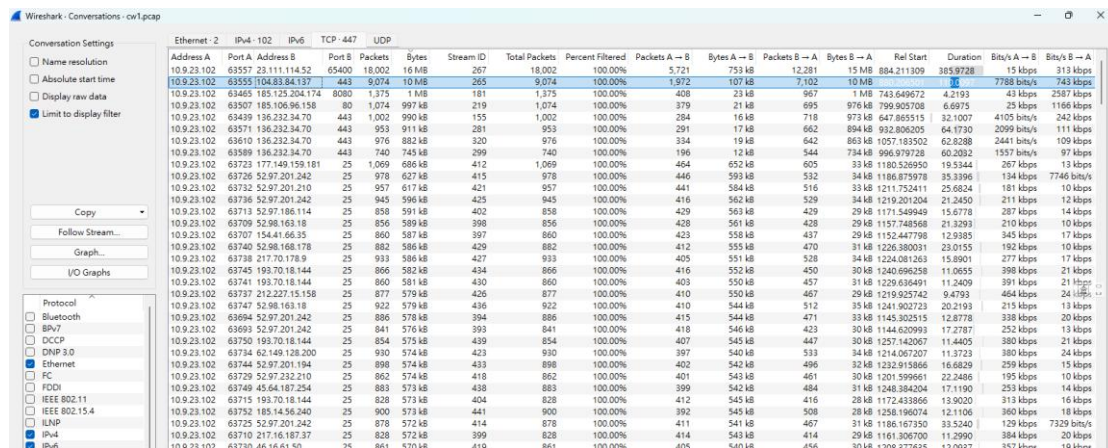
Dw8YBxsEGmYFAAEJfR4NQk9mLTyQZdk5kyQmOyRGQglxEBo4LzK/EyYrMi1hOT8IyM7IhcnPzsoKJsguXgkLiSiJCxRgWAgIIDQUZG8oP08JF

HTTP/1.1 200 OK
Date: Fri, 24 Sep 2021 16:46:15 GMT
Server: Apache/2.4.49 (cPanel) OpenSSL/1.1.1 mod_bwlimited/1.4
X-Powered-By: PHP/5.6.40
Content-Length: 302
Strict-Transport-Security: ...max-age=15552000...
Connection: close
Content-Type: text/html; charset=UTF-8

Fig SO_CW1_Q16

Phrase 2 in the question set (Q9-12):

To check which two IP are the Cobalt Strike C2 server, I first search the statistics in Wireshark to find the IP list in the descending order of traffic frequency. (Fig SO_CW1_9A) And then, I check the IP on VirusTotal. Then, it is found in community comment that 185.106.96.158 and 185.125.204.174 are cobalt strike (Fig SO_CW1_9B and Fig SO_CW1_9C)



Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Total Packets	Percent Filtered	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B → A
10.9.23.102	63557	23.111.114.52	65400	18,002	16 MB	267	18,002	100.00%	5,721	753 kB	12,281	15 MB	884.211.309	385.9728	15 kbps	313 kbps
10.9.23.102	63555	104.83.84.137	443	9,074	10 MB	265	9,074	100.00%	1,972	107 kB	7,102	10 MB	884.211.309	385.9728	15 kbps	313 kbps
10.9.23.102	63465	185.125.204.174	8080	1,375	1 MB	181	1,375	100.00%	408	23 kB	967	1 MB	743.649672	4.2193	43 kbps	2587 kbps
10.9.23.102	63507	185.106.96.158	80	1,074	997 kB	219	1,074	100.00%	379	21 kB	695	976 kB	799.950706	6.6975	25 kbps	1166 kbps
10.9.23.102	63439	136.232.34.70	443	1,002	990 kB	155	1,002	100.00%	284	16 kB	718	973 kB	647.85515	32.1007	4105 kbps	242 kbps
10.9.23.102	63571	136.232.34.70	443	953	911 kB	281	953	100.00%	291	17 kB	662	894 kB	932.806205	64.1730	2099 kbps	111 kbps
10.9.23.102	63610	136.232.34.70	443	976	882 kB	320	976	100.00%	334	19 kB	642	863 kB	1057.183502	62.8288	2441 kbps	109 kbps
10.9.23.102	63586	136.232.34.70	443	740	743 kB	399	740	100.00%	196	12 kB	544	734 kB	996.979728	60.2032	1557 kbps	97 kbps
10.9.23.102	63723	177.149.159.181	25	1,069	686 kB	412	1,069	100.00%	464	652 kB	605	33 kB	1180.526950	19.5344	267 kbps	13 kbps
10.9.23.102	63726	52.97.201.242	25	978	627 kB	415	978	100.00%	446	593 kB	532	34 kB	1186.875978	35.3396	134 kbps	7746 kbps
10.9.23.102	63732	52.97.201.210	25	957	617 kB	421	957	100.00%	441	584 kB	516	33 kB	1211.752411	25.6824	181 kbps	10 kbps
10.9.23.102	63736	52.97.201.242	25	945	596 kB	425	945	100.00%	416	562 kB	539	34 kB	1219.201204	21.2450	211 kbps	12 kbps
10.9.23.102	63713	52.97.186.114	25	858	591 kB	402	858	100.00%	429	563 kB	429	29 kB	1171.549949	15.6778	287 kbps	14 kbps
10.9.23.102	63709	52.98.163.18	25	856	589 kB	398	856	100.00%	428	561 kB	428	29 kB	1157.748568	21.3293	210 kbps	10 kbps
10.9.23.102	63707	154.41.66.35	25	860	587 kB	397	860	100.00%	423	558 kB	437	29 kB	1152.447798	12.9385	345 kbps	17 kbps
10.9.23.102	63740	52.98.168.178	25	882	586 kB	429	882	100.00%	412	555 kB	470	31 kB	1226.380031	23.0155	192 kbps	10 kbps
10.9.23.102	63738	217.70.178.9	25	933	586 kB	427	933	100.00%	405	551 kB	528	34 kB	1224.081263	15.8901	277 kbps	17 kbps
10.9.23.102	63745	193.70.18.144	25	866	582 kB	434	866	100.00%	416	552 kB	450	30 kB	1240.896258	11.0655	398 kbps	21 kbps
10.9.23.102	63741	193.70.18.144	25	860	581 kB	430	860	100.00%	403	550 kB	457	31 kB	1229.056491	11.2409	391 kbps	21 kbps
10.9.23.102	63737	212.227.15.158	25	877	579 kB	426	877	100.00%	410	550 kB	467	29 kB	1219.925742	9.4793	464 kbps	24 kbps
10.9.23.102	63747	52.98.163.18	25	922	579 kB	436	922	100.00%	410	544 kB	512	35 kB	1241.902723	20.2193	215 kbps	13 kbps
10.9.23.102	63694	52.97.201.242	25	886	578 kB	394	886	100.00%	415	544 kB	471	33 kB	1145.302515	12.8778	338 kbps	20 kbps
10.9.23.102	63693	52.97.201.242	25	841	576 kB	393	841	100.00%	418	540 kB	423	30 kB	1144.020993	17.2787	252 kbps	13 kbps
10.9.23.102	63750	193.70.18.144	25	854	575 kB	439	854	100.00%	407	545 kB	447	30 kB	1257.142067	11.4405	380 kbps	20 kbps
10.9.23.102	63734	62.149.128.200	25	930	574 kB	423	930	100.00%	397	540 kB	533	34 kB	1214.067207	11.3723	380 kbps	24 kbps
10.9.23.102	63744	52.97.201.194	25	898	574 kB	433	898	100.00%	402	542 kB	496	32 kB	1232.915866	16.6829	259 kbps	15 kbps
10.9.23.102	63729	52.97.232.210	25	862	574 kB	418	862	100.00%	401	543 kB	461	30 kB	1201.599651	22.2466	195 kbps	10 kbps
10.9.23.102	63749	45.64.187.254	25	883	573 kB	438	883	100.00%	399	542 kB	484	31 kB	1248.384204	17.1190	253 kbps	14 kbps
10.9.23.102	63715	193.70.18.144	25	828	573 kB	404	828	100.00%	412	545 kB	416	28 kB	1172.433866	13.9020	313 kbps	16 kbps
10.9.23.102	63752	185.14.56.340	25	900	573 kB	441	900	100.00%	392	545 kB	508	28 kB	1256.196074	12.1106	360 kbps	18 kbps
10.9.23.102	63725	52.97.201.242	25	878	572 kB	414	878	100.00%	411	541 kB	467	31 kB	1186.167350	33.5240	129 kbps	7320 kbps
10.9.23.102	63710	217.16.187.37	25	828	572 kB	399	828	100.00%	414	543 kB	414	29 kB	1161.306700	11.2990	384 kbps	20 kbps
10.9.23.102	63730	46.16.61.50	25	861	570 kB	419	861	100.00%	405	540 kB	456	30 kB	1708.377635	17.0947	357 kbps	19 kbps

Fig SO_CW1_Q9A

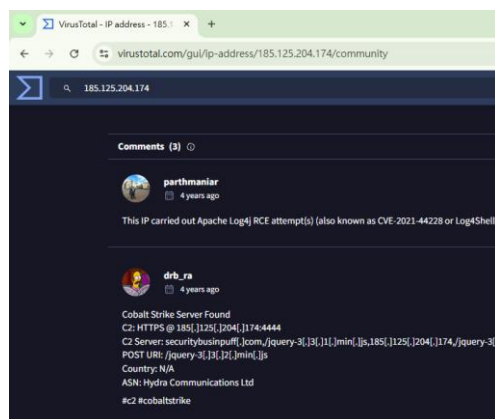


Fig SO_CW1_Q9B

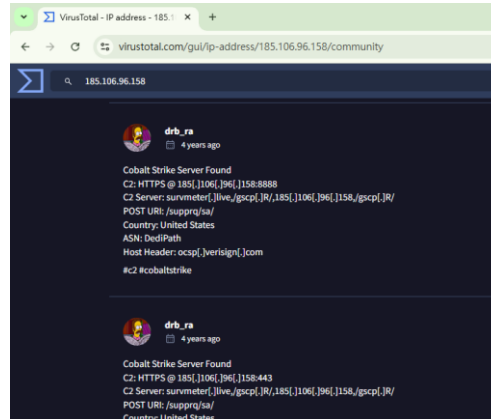
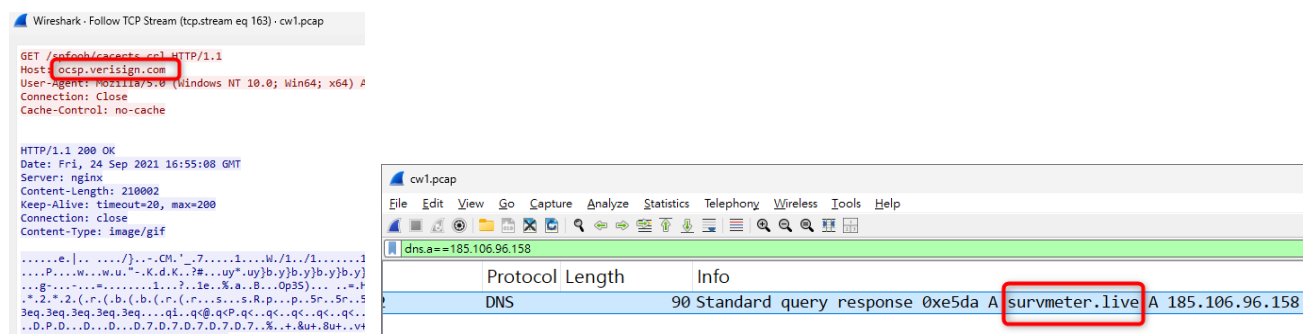


Fig SO_CW1_Q9C

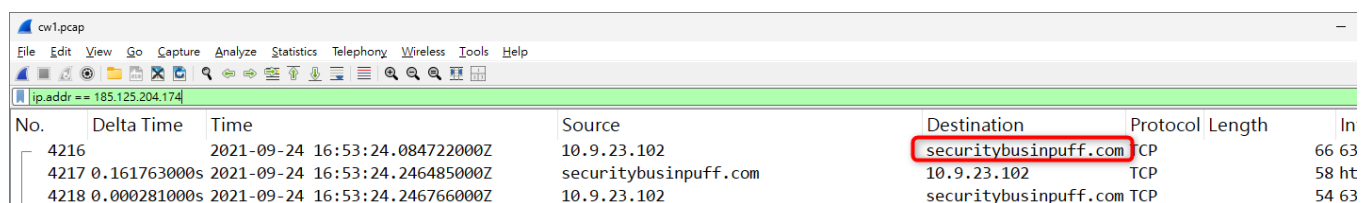
From question 10 to 12 are the information about these Cobalt Strike server. (Fig SO_CW1_Q10, Fig SO_CW10, Q11, SO_CW1_Q12_)



No.	Delta Time	Time	Source	Destination	Protocol	Length	In
4216		2021-09-24 16:53:24.084722000Z	10.9.23.102	securitybusinpuuff.com	CP	66	63
4217	0.161763000s	2021-09-24 16:53:24.246485000Z	securitybusinpuuff.com	10.9.23.102	TCP	58	ht
4218	0.000281000s	2021-09-24 16:53:24.246766000Z	10.9.23.102	securitybusinpuuff.com	TCP	54	63

Fig SO_CW1_Q10

Fig SO_CW1_Q11



No.	Delta Time	Time	Source	Destination	Protocol	Length	In
4216		2021-09-24 16:53:24.084722000Z	10.9.23.102	securitybusinpuuff.com	CP	66	63
4217	0.161763000s	2021-09-24 16:53:24.246485000Z	securitybusinpuuff.com	10.9.23.102	TCP	58	ht
4218	0.000281000s	2021-09-24 16:53:24.246766000Z	10.9.23.102	securitybusinpuuff.com	TCP	54	63

SO_CW1_Q12_

Phrase 3 in the question set (Q17-18):

The malware check the victim's IP by requesting victim to lookup the external IP in ipify.org (Fig SO_CW1_Q17)

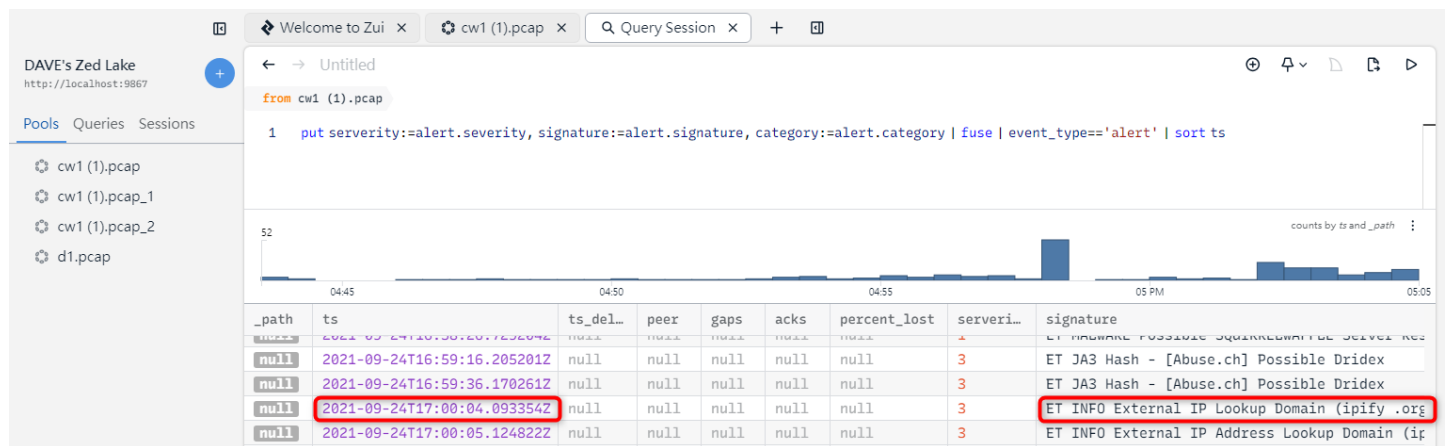


Fig SO_CW1_Q17

And the domain name of previous DNS query is found. (Fig SO_CW1_Q18)

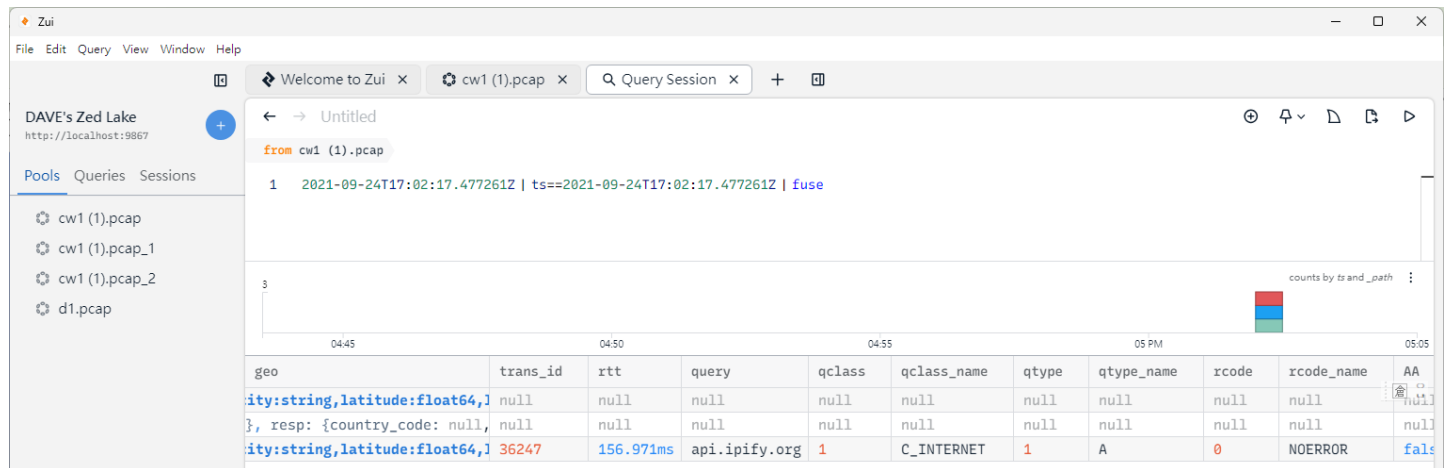


Fig SO_CW1_Q18

Phrase 4 in the question set (Q19-20):

Victims sends spam emails to other computers through port 25 using SMTP protocol. These emails are spam because I search one of the victim's target 93.89.226.88 in Virustotal the COUPON which is the content of the spam email. There is the spelling mistake is to escape from the spam mail filter.

The first email observed are found in Zui as below (Fig SO_CW1_Q19):

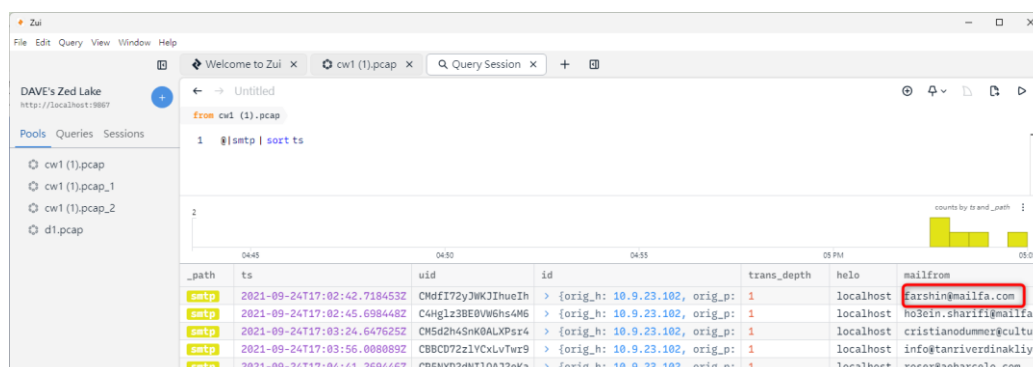


Fig SO_CW1_Q19

After follow TCP stream in Wireshark, the “Password” is found in the CyberChef. (Fig SO_CW1_Q20)

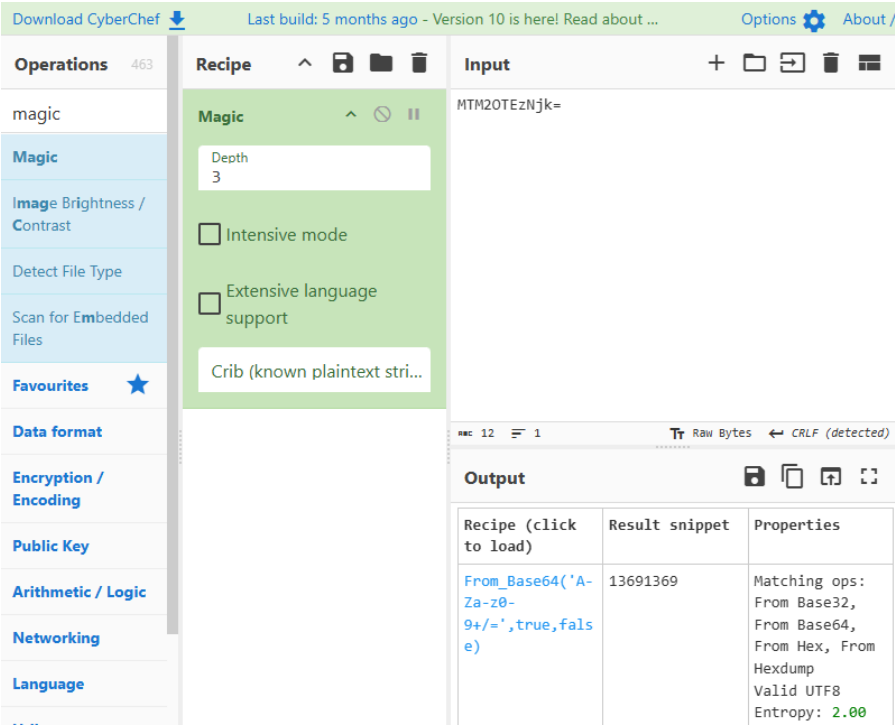


Fig SO_CW1_Q20

(4) Conclusion

To conclude, the victim is totally controlled by the hacker malwares. Therefore, it needs to have Windows reinstalled. To prevent the similar attack in the future, it is suggested that not to open the attached file in the suspicious emails.

(5) References

Github Link : <https://github.com/wingftsui/COMP3010HK-CW1>

Video evidence is in the above github.